

Cybersecurity - Kontrollfragen



Dozent: Prof. Dr. Michael Eichberg
Kontakt: michael.eichberg@dhbw.de, Raum 149B
Version: 1.3

1. Allgemeines



Klassenraumübung

Die folgenden Fragen sind *exemplarisch* für Fragen wie sie in einer Prüfung vorkommen könnten.

1.1. Schlüsselterminologie beherrschen

Backups:

- Was besagt die RPO?
- Was besagt die RTO?

1.2. Was besagt – im Zusammenhang mit Backups – die 3-2-1(+1) Regel?

1.3. Sollten Backups verschlüsselt werden? Wenn ja - aufgrund welcher Bedrohungen? Wobei entstehen dabei ggf. Herausforderungen?

1.4. Welches sind die drei primären Schutzziele der IT Sicherheit?

1.5. Wovor müssen IT Systeme geschützt werden?

1.6. Beschreiben Sie kurz was die *Mean Time to Contain* bei Sicherheitsvorfällen besagt?

1.7. Benennen Sie Arten/Kategorien von Angriffen?

1.8. Was ist OSInt?

1.9. Benennen Sie Gefahren für die IT Sicherheit, die vom Einsatz von KI ausgehen können.

1.10. Beschreiben Sie ein realistisches Szenario für Quishing/QR phishing?

1.11. Welchem Zweck dienen Bug-Bounty Programme?

1.12. Beschreiben Sie was ein Seitenkanalangriff ist und geben Sie ein Beispiel.

1.13. Ist immer ein Timing-Angriff möglich bei nicht-konstantem Zeitverhalten?

Sie haben folgende Situation: Ein Client übermittelt das Passwort in gehashter Form (H_1) an den Server. Der Server hasht den Hash noch einmal in Verbindung mit einem Salt $H_2 = \text{hash}(H_1 \parallel \text{SALT})$. Danach vergleicht er den berechneten Wert H_2 mit dem äquivalent konstruierten, gespeicherten Hash H_2 (gespeichert). Ist in diesem Szenario eine Timing-Angriff möglich?

♦ Bemerkung: Hash-Funktionen: Zur Erinnerung/Als Hinweis

Jede noch so kleine Änderung an H_1 führt zu einem pseudo-zufällig komplett neuen H_2 .

♦ Bemerkung

Diese Aufgabe erfordert ein grundlegendes Verständnis von kryptografischen Hash-Funktionen und Salt-Verfahren, welche wir in der Vorlesung behandeln werden; spätestens danach sollten Sie diese Aufgabe lösen können.



Einfache Wissensfragen, damit man mitdiskutieren kann...

- Wer ist die CISA?
- PQC ist die Abkürzung für?
- Wofür steht **KEV**?
- Wie hängen die Begriffe Exploit und PoC zusammen?
- Was ist Triple-Extortion Ransomware?
- Was unterscheidet Viren und Würmer?
- Wie unterscheidet sich Spear-Phishing von Phishing?
- Charakterisieren Sie Supply-Chain-Angriffe (im Kontext der IT-Sicherheit).
- Was ist ein Infostealer bzw. welchen Zweck verfolgt er?
- Ist Adware Malware?
- Was ist ein Software Defined Radio (SDR)? Welche Gefahr geht davon aus?
- Beschreiben Sie ganz kurz die Idee einer *Cold-Boot-Attacke*?
- Was ist eine Backdoor?
- Kann ich mich vor APT-Angriffen schützen?

2. NIS 2



Klassenraumübung

2.1. Wer ist betroffen von NIS2?